

CyberTech Nexus – Initial GRC Engagement

Organization Overview

Company Name: CyberTech Nexus

Industry: Financial Technology (FinTech)

Employees: 200

Business Operations:

CyberTech Nexus is a growing fintech startup responsible for handling highly sensitive information including customer data, payment card information, and employee records. Core systems support online financial services, customer account management, internal HR functions, and cloud-hosted infrastructure.

Scenario

As the newly hired GRC Analyst, I have been tasked with building the organization's foundational governance, risk, and compliance program from the ground up.

The Chief Information Security Officer (CISO) has stated:

"We've never documented our risks. We have no policies. Can you fix that?"

Initial Assessment

Current observations indicate several foundational gaps:

1. No documented risk register exists.
2. Security policies and standards have not been formally developed.
3. No formalized risk assessment process has been established.
4. Security responsibilities and ownership may not be clearly defined.
5. There is no evidence of a structured control framework implementation.

Potential Risks Identified

The absence of governance controls could create several organizational risks:

- Unauthorized access to sensitive customer information
- Exposure of credit card data
- Insider threats and privilege misuse
- Compliance failures
- Increased vulnerability to phishing and cyber attacks
- Cloud misconfigurations and data leakage

Immediate GRC Action Plan

Phase 1: Understand the Environment

- Identify critical business assets
- Identify data types and sensitivity levels
- Identify key stakeholders and system owners
- Review current technologies and business processes

Phase 2: Create Initial Risk Register

- Document critical assets
- Identify threats and vulnerabilities
- Determine likelihood and impact ratings
- Identify existing and missing controls
- Assign risk ownership

Phase 3: Establish Governance Foundations

- Create core security policies
- Define standards and procedures
- Establish roles and responsibilities

Phase 4: Align to Security Frameworks

- Review ISO 27001 Annex A controls
- Map controls to NIST Cybersecurity Framework functions:
 - Identify
 - Protect
 - Detect
 - Respond
 - Recover

Expected Deliverables

1. Initial Risk Register
2. Password Policy
3. Remote Work Policy
4. Access Control Policy
5. Risk Assessment Methodology
6. Security Awareness Program Recommendations
7. Initial Compliance Gap Assessment

Objective

The goal is to transform an undocumented and reactive security environment into a structured, measurable, and risk-based security program.

Password Policy — CyberTech Nexus

Purpose

The purpose of this policy is to establish password requirements that protect company systems and sensitive information from unauthorized access.

Policy Requirements

1. All user passwords must contain a minimum of 12 characters.
2. Passwords should contain a combination of:
 - Uppercase letters
 - Lowercase letters
 - Numbers
 - Special characters
3. Multi-factor authentication (MFA) is required for:
 - Corporate email
 - Cloud platforms
 - Administrative systems
 - Remote access systems
4. Password reuse across company systems is prohibited.
5. Users may not share passwords with any person, including coworkers.
6. Default passwords on applications and devices must be changed immediately upon deployment.
7. Password managers approved by CyberTech Nexus are strongly encouraged.
8. Any suspected credential compromise must be reported immediately to the Information Security team.

Compliance

Failure to comply with this policy may result in disciplinary action and access restrictions.

Remote Work Policy — CyberTech Nexus

Purpose

The purpose of this policy is to define security expectations for employees working remotely.

Policy Requirements

1. Employees must connect through company-approved VPN services while accessing internal systems.
2. Customer data, payment data, and employee records must not be stored locally on personal devices.
3. Company-issued devices should be used for business activities whenever possible.
4. Devices accessing company systems must:
 - Have updated antivirus software
 - Use encrypted storage
 - Maintain current security patches
5. Public Wi-Fi networks should not be used unless connected through company VPN protection.
6. Employees must lock devices when unattended.
7. Security incidents, lost devices, or suspected compromises must be reported immediately.

Compliance

Violations of this policy may result in disciplinary action and restricted remote access privileges.

Access Control Policy — CyberTech Nexus

Purpose

The purpose of this policy is to ensure access to systems and data is granted only to authorized personnel.

Policy Requirements

1. Access must be granted based on the principle of least privilege.
2. Access to production systems and customer data requires approval from the designated system owner.
3. Role-Based Access Control (RBAC) will be used whenever possible.
4. Administrative privileges should be limited to authorized personnel only.
5. User access reviews must occur quarterly.
6. User accounts for terminated employees must be disabled immediately.
7. Shared accounts are prohibited unless approved by Information Security.
8. All privileged activities should be logged and monitored.

Compliance

Non-compliance may result in revocation of system access and disciplinary action.

This now resembles the type of first-day deliverable a junior or entry-level GRC analyst could realistically produce: a risk register, prioritization exercise, and baseline governance documentation that can later align with frameworks like NIST Cybersecurity Framework, ISO/IEC 27001, or Payment Card Industry Security Standards Council for a fintech environment.

CyberTech Nexus — Risk Quantification Assessment

Organization: CyberTech Nexus
Industry: FinTech
Assessment Owner: GRC Analyst

Purpose

The purpose of this assessment is to quantify organizational risks using a standardized scoring methodology to support business decision-making and remediation prioritization.

RISK SCORING METHODOLOGY

Likelihood Scale

- 1 = Rare
- 2 = Unlikely
- 3 = Possible
- 4 = Likely
- 5 = Almost Certain

Impact Scale

- 1 = Negligible
- 2 = Minor
- 3 = Moderate
- 4 = Major
- 5 = Severe

Risk Formula

Total Risk Score = Likelihood × Impact

Risk Ratings

- 1–5 = Low Risk
- 6–10 = Medium Risk
- 11–15 = High Risk
- 16–25 = Critical Risk

5 × 5 RISK MATRIX

Impact →

Likelihood ↓ 1 2 3 4 5

5	5	10	15	20	25
4	4	8	12	16	20
3	3	6	9	12	15
2	2	4	6	8	10
1	1	2	3	4	5

RISK QUANTIFICATION REGISTER

Risk ID: R-001

Asset:
Customer Database

Threat:
SQL Injection causing customer and payment data exposure

Likelihood:
3 (Possible)

Impact:
5 (Severe)

Risk Score:
15

Risk Level:
High

Business Impact Categories:

Financial:
Potential revenue loss, legal expenses, and breach response costs

Operational:
Service interruption and recovery efforts

Regulatory:
Potential payment data and privacy violations

Reputational:
Loss of customer trust and brand damage

Risk ID: R-002

Asset:
Email System

Threat:
Phishing leading to credential compromise

Likelihood:
4 (Likely)

Impact:
4 (Major)

Risk Score:
16

Risk Level:
Critical

Business Impact Categories:

Financial:
Fraud and incident response costs

Operational:
Business email compromise and system disruption

Regulatory:
Possible unauthorized access to sensitive records

Reputational:
Reduced customer confidence

Risk ID: R-003

Asset:
Web Application

Threat:
Application exploitation or denial-of-service attack

Likelihood:
3 (Possible)

Impact:
4 (Major)

Risk Score:
12

Risk Level:
High

Business Impact Categories:

Financial:
Loss of revenue during outages

Operational:
Customer service disruption

Regulatory:
Potential security compliance concerns

Reputational:
Negative customer experience

Risk ID: R-004

Asset:
HR Portal

Threat:
Unauthorized access to employee records

Likelihood:
3 (Possible)

Impact:
4 (Major)

Risk Score:
12

Risk Level:
High

Business Impact Categories:

Financial:
Investigation and remediation costs

Operational:
Human resources process disruption

Regulatory:
Employee privacy compliance concerns

Reputational:
Loss of employee trust

Risk ID: R-005

Asset:
Cloud Infrastructure

Threat:
Cloud misconfiguration exposing sensitive systems

Likelihood:
4 (Likely)

Impact:
5 (Severe)

Risk Score:
20

Risk Level:
Critical

Business Impact Categories:

Financial:
Large-scale remediation and breach costs

Operational:
Critical systems unavailable

Regulatory:
Potential compliance violations

Reputational:
Significant customer confidence damage

EXECUTIVE SUMMARY

Highest-Risk Areas Identified:

- 1. Cloud Infrastructure Exposure (Score: 20 – Critical)
- 2. Email Credential Compromise (Score: 16 – Critical)
- 3. Customer Database Exposure (Score: 15 – High)

Recommendation:

Prioritize remediation activities according to risk score and business impact. Immediate focus should be placed on cloud security controls, phishing prevention measures, and database protection mechanisms.

Business Value:

Risk quantification translates technical threats into measurable business outcomes, enabling leadership to make informed decisions regarding resource allocation and risk treatment priorities.

CyberTech Nexus — Internal Audit Simulation

Audit Type: Internal Security Controls Assessment

Organization: CyberTech Nexus

Auditor: GRC Analyst

Audit Scope:
Assessment of key security controls supporting customer data, payment information, employee records, and cloud infrastructure.

Audit Objective:
Determine whether required security controls are implemented and whether evidence exists to support compliance.

AUDIT CHECKLIST

Control ID	Control Description	Evidence Type	Status
A.9.2.3	Privileged access reviews	Access review report and user access logs	Pending
A.12.6.1	Vulnerability management	Most recent vulnerability scan report	Complete
A.9.4.2	Multi-factor authentication for critical systems	Authentication configuration screenshots and system settings	Complete
A.7.2.2	Security awareness training	Employee training completion reports	Pending
A.12.4.1	Event logging and monitoring	SIEM logs and monitoring reports	Complete
A.8.2.3	Data classification and handling	Data classification documentation	Missing
A.12.1.2	Change management procedures	Change approval records	Pending

AUDIT FINDINGS

Finding #1

Control:

A.9.2.3 — Privileged Access Reviews

Observation:

No documented evidence exists showing quarterly privileged account reviews.

Risk Rating:

High

Potential Risk:

Excessive or unauthorized access privileges may remain active, increasing the likelihood of insider misuse or unauthorized access.

Remediation Plan:

- Implement quarterly access review process
- Assign system owners responsibility for access approval
- Maintain access review documentation
- Store evidence in centralized audit repository

Target Completion:

30 Days

Finding #2

Control:

A.7.2.2 — Security Awareness Training

Observation:

Training completion records could not be produced during audit review.

Risk Rating:

Medium

Potential Risk:

Employees may be more susceptible to phishing attacks and social engineering attempts.

Remediation Plan:

- Deploy mandatory security awareness training
- Track employee completion status
- Establish annual refresher training requirements

Target Completion:

45 Days

Finding #3

Control: A.8.2.3 — Data Classification and Handling

Observation: No formal data classification standard exists.

Risk Rating: High

Potential Risk: Sensitive customer and payment information may receive inadequate protection.

Remediation Plan:

- Develop data classification policy
- Create categories:
 - Public
 - Internal
 - Confidential
 - Restricted
- Train employees on handling requirements

Target Completion: 60 Days

EXECUTIVE AUDIT SUMMARY REPORT

Audit Conclusion:

CyberTech Nexus has established foundational security controls; however, documentation and evidence collection processes remain immature.

Three significant findings were identified:

1. Missing privileged access review evidence
Risk Rating: High
2. Missing employee security awareness evidence
Risk Rating: Medium
3. Lack of formal data classification controls
Risk Rating: High

Overall Risk Assessment: Moderate–High

Recommended Corrective Actions:

- Establish recurring control review procedures
- Implement centralized evidence management
- Develop missing policies and standards
- Assign ownership for all security controls
- Track remediation activities through formal action plans

Final Auditor Assessment:

CyberTech Nexus demonstrates progress toward building a structured security program but requires improvements in governance documentation and evidence retention to strengthen compliance readiness.

"My GRC Portfolio" Hands-on GRC portfolio project.

Contents included:

- **Password_Policy.docx**
- **Remote_Work_Policy.docx**
- **Access_Control_Policy.docx**
- **Risk_Register.xlsx**
- **Audit_Report.docx**
- **README.docx** (portfolio overview)

My_GRC_Portfolio_GoogleDocs_Ready - (folder is packaged and downloadable)